学习任务单 S03:微服务架构总览与网关信任链

学习领域 LF2 | 第 3 周 | 4 课时(180min)| 双元制六步法+费曼讲台

布鲁姆目标(本课你要达到)

- **[解]** 解释零信任:服务为何只信网关注入的头
- **[应]** 复现 403→带头→200 的信任链实验
- **[析]** 诊断'直连 403'到底是 bug 还是安全设计

情境导入(资讯)

企业情境:测试同学报障'tenant 接口 403,系统坏了!'——你上手一看,带头就好了。这是一次真实发生的事:区分'故障'与'安全设计'是工程师的必修课。

上节回顾

对账表收缴;抽 1 组展示证据行。

计划与决策

1. 工单员领单,组内宣读目标与交付物;
2. 拆解实训步骤,分配操作员/检查员;
3. 向教师陈述 30 秒方案,**重申安全红线**(禁 L2/L3 越权操作)。

知识建构精讲要点(理论 35min,教师主持)

网关在微服务里的角色

- nginx-gateway 统一入口:路由/鉴权/限流/注入身份头
- 上游服务不直接解析 JWT,而信任网关注入的 X-User-* 头

信任链与零信任

- HeaderAuthFilter 只信 X-Gateway-Verified=1(网关注入)
- 直连 NodePort 没有该头→403——这是设计,不是故障
- 推论:任何'带头就 200'的实验都在证明信任链在工作

NodePort 直连 vs 网关路径

- NodePort:31826(iam)/31965(tenant)/31429(course) 调试通道
- 生产路径:经网关(带校验头)——两条路径的语义不同
- 调试纪律:测试结论必须注明'走了哪条路径'

实训实施(70min,双师巡回)

1. **1. 复现 403** — 不带 X-Gateway-Verified 直接 curl tenant 学分规则创建接口 → 403
2. **2. 带头对比** — 补 X-Gateway-Verified:1 + X-User-Roles:ROLE_SUPER_ADMIN → 200
3. **3. 写实验报告** — 记录两组请求/响应,结论:403=安全设计;规则创建无 DomainEvent 为遗留
4. **4. 反向测试** — 带头但角色为 ROLE_STUDENT → 应 403(授权仍然生效)

检查清单(15min,检查员主持·互查组复核)

- □ [应] 403/200/403 三组请求证据齐全
- □ [析] 能说清 403 的判定发生在哪一层(Filter)
- □ [评] 能把'安全设计 vs bug'判据写成一句话给测试同学

费曼讲台(15min)

讲题:给外行讲'为什么公司前台不让陌生人直接进办公室,但你带着工牌还得刷卡'类比信任链。 规程:白纸讲授 6min(不看笔记)→同伴追问 4min(卡壳即回炉)→类比压缩 3min。未过检查清单的小组不得上台。

课后作业

- 费曼卡#3:零信任一句话+类比图
- 实验报告补第 4 组反向测试证据

评分点

三组实验证据(50%)+报告结论准确(30%)+反向测试(20%)

证据纪律:所有'完成'必须附命令输出/截图;如实记录失败与返工(诚实=加分)。